NIST CSF
Control Mapping

April 2026

Summary

This project demonstrates the alignment of cybersecurity controls with the NIST Cybersecurity Framework (CSF). Controls were mapped to NIST functions, categories, and subcategories, and further aligned with NIST SP 800-53 control families. This mapping supports structured risk management, improves visibility into control coverage, and helps identify gaps in security posture.

Control Coverage Insight

Most controls fall under the “Protect” function, indicating a strong focus on preventative security. Fewer controls exist in Detect and Respond, highlighting potential areas for improvement in monitoring and incident response capabilities.

Mapping Overview

This project maps cybersecurity controls to the NIST Cybersecurity Framework (CSF) to demonstrate alignment with industry standards. Each control is mapped to relevant NIST functions, categories, and subcategories, and further aligned with NIST SP 800-53 controls. This approach supports structured risk management and helps identify gaps in control coverage.

Control ID	Control Description	Control Type	NIST Function	NIST Category	NIST Subcategory	Related Control (800-53)	Risk Addressed	Implementation Status
C-01	Implement multi-factor authentication (MFA)	Preventive	Protect	PR.AC	PR.AC-7	IA-2	Phishing Attack	Planned
C-02	Deploy email filtering and anti-phishing tools	Preventive	Protect	PR.DS	PR.DS-2	SC-7	Phishing Attack	Implemented
C-03	Conduct regular security awareness training	Preventive	Protect	PR.AT	PR.AT-1	AT-2	Human Error	Planned
C-04	Establish patch management process	Preventive	Protect	PR.IP	PR.IP-12	SI-2	Unpatched Systems	Planned
C-05	Implement centralized logging and monitoring (SIEM)	Detective	Detect	DE.CM	DE.CM-1	AU-6	Lack of Monitoring	Planned
C-06	Conduct third-party vendor risk assessments	Preventive	Identify	ID.SC	ID.SC-1	SR-2	Vendor Security Risk	Planned
C-07	Enforce role-based access control (RBAC)	Preventive	Protect	PR.AC	PR.AC-4	AC-2	Weak Access Controls	Planned
C-08	Develop and maintain incident response plan	Corrective	Respond	RS.RP	RS.RP-1	IR-1	Multiple Risks	Planned
C-09	Establish data backup and recovery procedures	Corrective	Recover	RC.RP	RC.RP-1	CP-9	Data Loss	Planned